ESEN

# C I B E R S E G U R I D A D

## Proyecto Final · Entregable E.12

Presentación ejecutiva y defensa oral

**Ejemplo resuelto de cátedra** · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.12 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

**Docente:** Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

## Tabla de contenidos

Estructura y reparto del tiempo..... 3
Guion por bloque..... 4
Preparación de la ronda de preguntas..... 5

Ejemplo resuelto de cátedra · defensa del 12 al 14 de noviembre de 2026 (H6) · evalúa J.3 (10 %). Guion de diez minutos para seis expositores, con el reparto de tiempo, el contenido de cada bloque y la preparación de la ronda de preguntas.

## Estructura y reparto del tiempo

La presentación sigue las nueve diapositivas de la Guía del Estudiante del Proyecto Final (E.12) y añade dos anexos de respaldo para la ronda de preguntas. Está redactada para que un directivo sin contexto del curso entienda el diagnóstico, la línea base diseñada y la decisión que se le solicita. Archivo: E12_Presentacion_Ejecutiva_Defensa.pptx (y su PDF), generado con Herramientas/gen_e12_pptx.js.

| Lámina | Minuto | Expositor | Contenido | Bloque del guion |
|---|---|---|---|---|
| 1. Portada | 0:00 – 0:30 | Alejandra Beltrán Rivas, consultora líder | Organización, encargo, equipo y el tamaño del trabajo: 2 procesos críticos, 14 riesgos, 6 controles, 153 salvaguardas IG3 | 1 |
| 2. ENSA, el encargo y el alcance | 0:30 – 1:30 | Alejandra Beltrán Rivas | Perfil de ENSA, las cuatro etapas del trabajo, alcance del sistema de gestión y exclusiones justificadas | 1 |
| 3. Qué le cuesta a ENSA detenerse | 1:30 – 3:00 | Diego Salguero Martínez, analista de riesgos | Los dos procesos críticos y los dos importantes que el perfil declara críticos, con MTPD, RTO, RPO y costo por hora; los tres puntos únicos de falla del sistema de control | 2 |
| 4. Mapa de calor | 3:00 – 4:30 | Diego Salguero Martínez | Los catorce riesgos ubicados, los tres Críticos con su raíz común y el apetito aprobado | 2 |
| 5. Los seis controles | 4:30 – 6:30 | Rodrigo Peña Escobar, arquitecto de controles | Control, riesgos que trata, regla verificable y función CSF; argumento económico del tratamiento de R-01 (698 %, 219 % conservador) | 3 y 4 |
| 6. Línea base IG3 | 6:30 – 7:15 | Iván Cardoza Linares, oficial de calidad | 153 = 107 + 46, distribución de estados y 56 IG1 = 41 + 15 | 5 |
| 7. Indicadores y auditoría | 7:15 – 8:00 | Iván Cardoza Linares | Los tres indicadores sin tolerancia y el programa de auditoría interna de marzo de 2027 | 5 |
| 8. Roadmap | 8:00 – 9:15 | Paola Mena Quintanilla, oficial de documentación | Tres horizontes con inversión, iniciativas y salvaguardas; orden por dependencia | 6 |
| 9. Decisión y cierre | 9:15 – 10:00 | Alejandra Beltrán Rivas | Las seis medidas prioritarias y las dos decisiones solicitadas | 6 y 7 |
| Anexo A. Supuestos | Preguntas | Mariela Cortez Aguilar, analista de riesgos | Los supuestos que gobiernan la conclusión y la prueba de sensibilidad | 3 |

| Lámina | Minuto | Expositor | Contenido | Bloque del guion |
|---|---|---|---|---|
| Anexo B. Iniciativas | Preguntas | Paola Mena Quintanilla | Las veintinueve iniciativas de la ruta por horizonte | 6 |

## Guion por bloque

### Bloque 1 — Apertura y encargo

ENSA distribuye energía eléctrica a clientes residenciales e industriales, con 550 empleados, un centro de operaciones en San Salvador y subestaciones en todo el territorio. El encargo del equipo fue construir la línea base de seguridad de la información de la organización: analizar el impacto de la interrupción de sus procesos, evaluar sus riesgos, diseñar controles y trazar la ruta hacia el Grupo de Implementación 3 que su perfil de riesgo exige. Al final de esta presentación la dirección decide sobre seis medidas prioritarias y sobre dos puntos que no admiten postergación.

### Bloque 2 — Panorama de riesgos

El análisis de impacto evaluó diez procesos y confirmó dos como críticos, el telecontrol y la gestión de interrupciones; el sistema comercial y la medición inteligente, que el perfil declara críticos, resultaron importantes. La cifra que ordena todo el trabajo es esta: el telecontrol de la red tolera cuatro horas de interrupción y cada hora sin él cuesta USD 62 000 en temporada de lluvias; el sistema de facturación, en cambio, tolera setenta y dos horas. Esa distancia decide dónde se invierte primero.

De los catorce riesgos evaluados, tres son Críticos y diez Altos. Los tres Críticos comparten raíz: la convergencia entre la red de TI y la red de tecnología operacional existe de hecho y no está gobernada. El propio perfil de ENSA lo reconoce cuando describe un aislamiento que en la práctica no es real. Ransomware que cruza desde la red corporativa al entorno de control, acceso remoto del proveedor del sistema SCADA sin segundo factor ni registro, y credenciales privilegiadas comprometidas por phishing: los tres llegan al mismo sitio.

### Bloque 3 — Qué sostiene el análisis

Ninguna de las cifras anteriores proviene del perfil del catálogo, porque el perfil no las trae. Cada una se declaró como supuesto con su origen, su fecha y su rango: diecisiete supuestos en total, de los cuales tres gobiernan la conclusión —el valor del proceso de control de red, el factor de exposición del evento de referencia y la duración máxima sostenible de la operación manual—. Los tres se sometieron a escenarios mínimo, esperado y máximo, y la recomendación de tratar el riesgo sobre el entorno SCADA se sostiene en los tres: el retorno de la inversión pasa de 698 % en el escenario esperado a 219 % en el más conservador, y sigue siendo positivo.

### Bloque 4 — Los seis controles clave

Los seis controles se eligieron desde los riesgos, no desde el catálogo. El control 12 y el 13 tratan la propagación entre redes y su detección; el 6 trata el acceso remoto de proveedores y las cuentas privilegiadas; el 11 trata la recuperación, que hoy no cumple el objetivo de dos horas; el 7 trata las vulnerabilidades del entorno de control, que se parchean sin calendario; y el 15 hace exigible la seguridad a los terceros de los que ENSA depende.

Cada control lleva política, procedimiento y controles por tipo. La diferencia entre una política que sirve y una que no está en si sus declaraciones se pueden verificar. Tres ejemplos del trabajo: ninguna sesión se origina desde la red de TI hacia la red OT sin pasar por el anfitrión de salto; toda cuenta es nominal, incluidas las de soporte del

fabricante; y ninguna prueba de restauración se declara satisfactoria sin verificación funcional firmada por el dueño del proceso.

**Bloque 5 — Baseline e indicadores**

El baseline de ENSA son las 153 salvaguardas del IG3. Cuarenta y seis quedan documentadas en los seis controles desarrollados y las 107 restantes en el checklist, cada una con medida, estado y evidencia: 41 salvaguardas IG1 en el checklist más 15 en los controles suman las 56 de la higiene esencial. El resultado del diagnóstico: una salvaguarda existente, trece parciales, diecisiete cubiertas por un tercero con contrato y cláusula nombrados, y setenta y seis pendientes. El programa se mide con doce indicadores, tres de ellos con meta del 100 % sin tolerancia, porque cada uno corresponde a un riesgo Crítico y una sola excepción reabre la condición que lo hizo Crítico.

**Bloque 6 — Roadmap y decisión solicitada**

Veintinueve iniciativas en tres horizontes: trece en los primeros seis meses, con USD 392 000 cotizados en nueve de ellas, que caben en el presupuesto anual comprometido; once en el mediano plazo, con USD 265 000 cotizados en ocho; y cinco en el largo, por USD 180 000. La migración a FortiOS 7.4 y la sustitución de Windows 10 se cotizan antes de iniciarlas. Hoy operan 18 de las 153 salvaguardas; al cierre del corto plazo operan 78, y al cierre del largo, las 153. El orden lo decide la dependencia técnica. El respaldo va primero porque sin él cualquier incidente excede el período máximo tolerable, aunque la segmentación tenga más efecto sobre la probabilidad.

Dos decisiones se solicitan hoy: validar la duración real del procedimiento alterno de operación manual, porque el simulacro alcanzó ocho horas y la ficha declara doce —si el valor real es el del simulacro, el período máximo tolerable baja y el objetivo de recuperación se vuelve más exigente—; y renegociar el anexo de seguridad del contrato del fabricante del sistema de control, del que dependen tres de las seis medidas prioritarias.

**Bloque 7 — Cierre**

Seis medidas, en este orden: respaldo con copia aislada y prueba de restauración; segmentación de los puntos de conexión entre redes; acceso remoto de proveedores con cuentas nominales, segundo factor y grabación; autenticación multifactor en toda cuenta administrativa con capacitación frente a la suplantación asistida por inteligencia artificial; inventario y detección en la red OT; y documentación del sistema de control con un segundo ingeniero formado. Ninguna exige tecnología excepcional. Todas exigen decisión, presupuesto y disciplina de operación.

## Preparación de la ronda de preguntas

| Pregunta previsible | Respuesta preparada y dónde está sustentada |
|---|---|
| ¿De dónde sale el costo de USD 62 000 por hora? | De cinco componentes declarados en la ficha del proceso: energía no suministrada, personal y horas extra, compensaciones contractuales, costo del procedimiento alterno y soporte de emergencia. El componente mayor, USD 38 000 de ingresos no percibidos, se deriva de la ficha (190 MW × USD 200 por MWh), y su rango va de USD 24 000 a 55 000 (BIA_P02, sección 8) |
| ¿Por qué el MTPD es de cuatro horas y no de ocho? | Porque la matriz de impacto cruza el umbral de tolerancia en el corte de cuatro horas, en las categorías de seguridad de las personas y operativa, y el dueño del proceso lo confirmó por la vía del agotamiento de la maniobra manual. Las dos derivaciones coinciden sin ajuste (BIA_P03, sección 5) |

| Pregunta previsible | Respuesta preparada y dónde está sustentada |
|---|---|
| ¿Por qué el sistema comercial y la medición inteligente no son críticos, si el perfil los declara así? | Porque su puntaje en BIA_P05, calculado con las consecuencias que la ficha trae para el corte de 24 horas, es de 2,46, por debajo del umbral de 2,90 que la dirección aprobó antes de calcular. Siguen en el alcance y conservan su valoración económica (BIA_P05; E.02, sección A.3) |
| ¿Por qué solo una salvaguarda existente? | Porque el equipo marcó como existente únicamente lo que la ficha registra en el bloque «Controles que ya existen»: la 9.1, navegador y cliente de correo soportados. Las medidas que la ficha describe solo en la red de TI quedan como existentes parciales. Declarar el estado real es lo que permite planificar la ruta (E.08) |
| ¿Por qué el control 13 se desarrolla si no tiene salvaguardas IG1? | Porque el baseline de ENSA es IG3, y las once salvaguardas del control 13 pertenecen al IG2 y al IG3. Su ausencia es la razón por la que hoy un incidente en la red OT sería indetectable (E.07, F.1 del control 13) |
| ¿El endurecimiento de los concentradores no se justifica? | Como proyecto propio, no: su retorno es de −8 % en el escenario esperado y solo se vuelve positivo en el máximo. Por eso se absorbe en el control 4 del baseline, donde su costo marginal es cercano a cero (E.05, tabla D.6) |
| ¿Qué pasa si la dirección aprueba solo el escenario mínimo de presupuesto? | Con USD 300 000 se mantienen las cuatro primeras iniciativas del corto plazo y se desplazan al mediano la gestión de dispositivos portátiles y la protección de correo, que son las de menor efecto sobre los riesgos Críticos (E.10) |
| ¿Por qué la notificación de brechas la aprueba la Gerencia General? | Porque el artículo 25 de la LPDP fija 72 horas y la decisión de notificar tiene consecuencias regulatorias y reputacionales que no admiten delegación tácita (E.06) |
| ¿Cómo se sabe que la segmentación funciona? | Por la prueba controlada del procedimiento: intento de conexión a tres servicios del entorno de control desde una estación corporativa, con evidencia de bloqueo, cada trimestre; y por el indicador IND-01, con meta del 100 % (E.07 y E.09) |

Cada integrante domina el proyecto completo y responde por cualquier parte, tal como el acta de conformación del equipo comprometió y como la rúbrica J.3 evalúa. El apoyo visual se mantiene sobrio: nueve láminas y dos anexos, sin texto que el expositor se limite a leer.